

מודול 14 — תקיפות אלחוטיות

חומר לימוד

1 יחידות

📺 **הכול בגלילה אחת:** כל החומר של המודול בקובץ אחד — חומר לימוד, תרגילים, תרגול ופתרונות, ברצף.

🎬 **מודול מעשי (חלקית) + הדגמה מקומית!** הלכידה והזרקת החבילות דורשות **מתאם USB** (ראו אזהרת החומרה) — אבל את **פיצוץ ה-Handshake**, שהוא הלב, אפשר לתרגל **בלי חומרה**: תורידו קובץ cap. אמיתי ותפצחו אותו עם aircrack-ng בדיוק כמו סיסמה (מודול 8). אחרי הנושאים: 🧠 **בדוק את עצמך**.

מודול 14 — תקיפות אלחוטיות (Wireless Attacks)

מטרות המודול: להבין כיצד עובדת אבטחת Wi-Fi ואיך תוקפים אותה. נלמד את משפחת הפרוטוקולים (WEP/WPA/WPA2/WPA3), נבצע **סריקת רשתות ו-לכידת Handshake**, נפצח סיסמאות WPA2, ונכיר מתקפות מתקדמות: **Evil Twin, Deauthentication, ו-WPS**. המודול מקנה את היכולת לבצע בדיקת אבטחה של רשת אלחוטית ארגונית.

קבצים: README.md · missions.md · solutions.md · practice.md · slides.md.

⚠️ **דרישת חומרה — קרא לפני שתתחיל!** תקיפות אלחוטיות דורשות **מתאם Wi-Fi חיצוני (USB)** שתומך ב-**Monitor Mode** ו-**Packet Injection** (למשל שבבי Atheros AR9271, Ralink RT3070, Realtek RTL8812AU). הכרטיס המובנה בלפטופ לרוב לא מספיק, וגם לא ניתן לבצע זאת ב-**VM** ללא **חיבור USB passthrough של מתאם תואם**. אם אין חומרה — הבן את התיאוריה מהמודול, ותרגל את **הפיצוץ** (החלק החישובי) על קבצי cap. להורדה. הפעולות האחרות דורשות מתאם פיזי.

תוכן העניינים

1. יסודות רשתות אלחוטיות
2. פרוטוקולי אבטחה: WPA3 → WEP
3. ציוד וסביבה (Monitor Mode)
4. סריקה ואיסוף מידע
5. Deauthentication ולכידת Handshake
6. פיצוץ WPA2
7. מתקפות מתקדמות: Evil Twin ו-WPS
8. הגנה על רשת אלחוטית

14.1 יסודות רשתות אלחוטיות

- **SSID** — שם הרשת המשודר.
- **BSSID** — כתובת ה-MAC של נקודת הגישה (Access Point / AP).
- **Client (STA)** — מכשיר מחובר (טלפון, לפטופ).
- **ערוצים (Channels)** — תדרים (2.4GHz / 5GHz) שבהם משדרים.
- **Beacon Frames** — ה-AP משדר את נוכחותו ברציפות.

תעבורה אלחוטית **משודרת באוויר** — כל מי שבטווח יכול "להאזין" (בניגוד לרשת קווית). לכן ההצפנה קריטית.

🎯 הרעיון המרכזי: אם אנחנו יכולים ללכוד את חבילות ה-**Handshake** (רגע ההתחברות), נוכל לנסות לפצח את הסיסמה offline — בדיוק כמו hashes (מודול 8).

14.2 פרוטוקולי אבטחה: WEP → WPA3

פרוטוקול	שנה	מצב אבטחה
WEP	1997	שבור לחלוטין — נפצח תוך דקות (חולשת IV)
WPA	2003	חלש (TKIP); פתרון ביניים
WPA2	2004	הנפוץ ביותר ; פגיע לפיצוח Handshake (סיסמה חלשה)
WPA3	2018	חזק (SAE); עמיד לפיצוח offline, אך מתקפות עדיין קיימות

המיקוד המעשי: רוב הרשתות עדיין **WPA2-PSK**. החולשה אינה בפרוטוקול עצמו אלא ב**סיסמה חלשה** — לוכדים Handshake ומפצחים במילון.

🔍 WEP הוא שריד היסטורי — אם תמצא אותו בבדיקה, זה ממצא קריטי מיידי. WPA2 בטוח כל עוד הסיסמה חזקה.

🧠 **בדוק את עצמך:** מצאת רשת שעדיין משתמשת ב-**WEP**. מה המשמעות? (א - הרשת בטוחה מאוד - ב) ממצא קריטי — WEP שבור לחלוטין וניתן לפיצוח תוך דקות - ג) אי אפשר לתקוף אותה

תשובה: ב — WEP שבור (חולשת ה-IV). נוכחותו היא ממצא קריטי מיידי לדוח, ללא קשר לחוזק הסיסמה. ✓

14.3 ציוד וסביבה (Monitor Mode)

Monitor Mode מאפשר למתאם ל"האזין" לכל התעבורה באוויר (לא רק לרשת שאליה מחובר). **Packet Injection** מאפשר לשלוח חבילות (נדרש ל-Deauth).

```
# זיהוי המתאם:
iwconfig                                # מחפשים wlan0

# הפעלת Monitor Mode (חבילת aircrack-ng):
sudo airmon-ng check kill                # עוצר תהליכים מפריעים
sudo airmon-ng start wlan0              # → wlan0mon במצב monitor

# אימות:
iwconfig wlan0mon                        # Mode:Monitor
```

⚠ אם airmon-ng לא מציג את הכרטיס במצב monitor — הכרטיס/הדרייבר לא תומך. זו הסיבה שצריך מתאם USB ייעודי.

14.4 סריקה ואיסוף מידע

airodump-ng סורק את כל הרשתות והלקוחות בסביבה:

```
sudo airodump-ng wlan0mon
```

פלט טיפוסית:

BSSID	PWR	CH	ENC	CIPHER	AUTH	ESSID
AA:BB:CC:11:22:33	-40	6	WPA2	CCMP	PSK	HomeNet
DD:EE:FF:44:55:66	-70	11	WPA2	CCMP	PSK	Office-WiFi

נבחר יעד (BSSID + ערוץ) ונתמקד בו כדי ללכוד Handshake:

```
sudo airodump-ng --bssid AA:BB:CC:11:22:33 -c 6 -w capture wlan0mon
# --bssid = היעד, -c = ערוץ, -w = שמירה לקובץ
```

עמודת **PWR** = עוצמת אות (קרוב יותר = מספר גבוה יותר, שלילי פחות). עמודת **STATION** (בתחתית) מראה לקוחות מחוברים — נזקק להם ל-Deauth.

Handshake ולכידת Deauthentication 14.5

ה-**Way Handshake-4** נלכד רק כשלקוח מתחבר ל-AP. במקום לחכות — נכריח לקוח קיים להתנתק (Deauth), והוא יתחבר מחדש אוטומטית → לוכדים.

```
# רץ על היעד, בטרמינל שני airodump-ng בזמן ש
sudo aireplay-ng --deauth 5 -a AA:BB:CC:11:22:33 -c <client-mac> wlan0mon
# --deauth 5 = שלח 5 חבילות ניתוק; -a = ה-AP; -c = הלקוח
```

—  **WPA handshake: AA:BB:CC:11:22:33** airodump-ng יציג למעלה: כשהלקוח מתחבר מחדש, — לכדנו.

Deauth  היא גם מתקפת **DoS** בפני עצמה (ניתוק מתמשך), אך כאן המטרה היא רק לכידת ה-Handshake. שלח מעט חבילות — לא צריך להטריד את הרשת.

 **בדוק את עצמך:** למה שולחים חבילות **Deauthentication** ללקוח מחובר? (א) כדי לפצח את הסיסמה ישירות - (ב) כדי לנתק אותו — שיתחבר מחדש, וכך נלכוד את ה-**Way Handshake-4** (ג) כדי להאיץ את הרשת

 **תשובה: ב** — ה-Handshake נלכד רק ברגע ההתחברות. Deauth מכריח התחברות-מחדש כדי שלא נחכה. (הסיסמה מפוצחת אחר כך, offline).

WPA2 פיצוח 14.6

ה-Handshake שנלכד מכיל את הסיסמה בצורה מוצפנת (PMK). מפצחים **offline** במילון:

```
# aircrack-ng:
sudo aircrack-ng capture-01.cap -w /usr/share/wordlists/rockyou.txt

# (hc22000-ממירים תחילה ל) hashcat מהיר יותר עם:
hcxpcapngtool -o hash.hc22000 capture-01.cap
hashcat -m 22000 hash.hc22000 /usr/share/wordlists/rockyou.txt
```

אם הסיסמה במילון — נקבל אותה. אם היא **חזקה** (ארוכה, אקראית) — הפיצוח ייכשל, וזה בדיוק מדוע WPA2 בטוח עם סיסמה טובה.

🔑 **החיבור למודול 8:** זהו בדיוק אותו רעיון של פיצוח סיסמאות offline — לוכדים "hash" (כאן: Handshake) ומפעילים מילון/WPA2. hashcat חזק = סיסמה שלא נמצאת בשום wordlist.

🎬 הדגמה — נסה בעצמך: פצח Handshake אמיתי (בלי חומרה!) 🚩

אין לך מתאם USB? לא נורא — את **הפיצוח**, החלק החשובי, עושים על קובץ cap. שנלכד מראש. זהו בדיוק החלק שתעשה גם עם חומרה.

צעד 1 — הורד את קובץ ה-Handshake הרשמי לתרגול (wpa.cap של aircrack-ng — הסיסמה שלו מתועדת: **biscotte**):

```
wget https://github.com/aircrack-ng/aircrack-ng/raw/master/test/wpa.cap
```

💡 הקובץ wpa.cap הוא קובץ הבדיקה הרשמי מהמדריך של aircrack-ng, והסיסמה שלו היא biscotte. אין אינטרנט? כל קובץ cap. עם Handshake תקין יעבוד.

צעד 2 — ודא שיש Handshake בקובץ:

```
aircrack-ng wpa.cap
```

👁️ aircrack מציג את הרשת (ESSID) ומסמן שיש **handshake** — יש לנו מה לפצח.

צעד 3 — פצח עם מילון (המילון הקטן **wifi_wordlist.txt** כבר מכיל את biscotte):

```
aircrack-ng wpa.cap -w wifi_wordlist.txt
# או עם המילון הגדול:
aircrack-ng wpa.cap -w /usr/share/wordlists/rockyou.txt
```

👁️ aircrack מכריז בגדול: **KEY FOUND! [biscotte]** 🎉

צעד 4 — הגרסה המהירה (hashcat):

```
hcxpcapngtool -o hash.hc22000 wpa.cap
hashcat -m 22000 hash.hc22000 wifi_wordlist.txt
```

🎯 **מה קרה כאן:** ה-Handshake מכיל הוכחה מוצפנת של הסיסמה. aircrack ניחש כל מילה מהמילון, חישב, והשווה — בדיוק כמו פיצוח hash (מודול 8). **הגנה:** סיסמת Wi-Fi ארוכה ואקראית (+15 תווים) שלא נמצאת בשום wordlist.

🧠 **בדוק את עצמך:** מה הופך רשת WPA2 לעמידה בפני הפיצוח הזה? (א) הסתרת ה-SSID (ב) סיסמה ארוכה ואקראית שאינה נמצאת באף wordlist (ג) כיבוי ה-Handshake

✅ **תשובה: ב** — הפיצוח הוא מילוני/Brute Force על ה-Handshake. סיסמה חזקה ואקראית פשוט לא נמצאת ברשימות — ולכן הפיצוח נכשל. (אי אפשר “לכבות” Handshake).

14.7 מתקפות מתקדמות: WPS ו-Evil Twin

Evil Twin (תאום מרושע)

מקימים **AP מזויף** עם אותו SSID של הרשת האמיתית. הקורבן מתחבר בטעות, ואנחנו יכולים ללכוד תעבורה או להציג **דף התחברות מזויף** (Captive Portal) שגונב את הסיסמה.

מאוטמים את כל התהליך – wifiphisher, airgeddon: כלים #

WPS Attacks

WPS (הכפתור/PIN לחיבור קל) פגיע למתקפת **brute-force** על ה-PIN (8 ספרות):

```
sudo reaver -i wlan0mon -b <BSSID> -vv
# פעיל WPS לזיהוי רשתות עם wash או
sudo wash -i wlan0mon
```

💡 **Evil Twin** מסוכן במיוחד כי הוא עוקף הצפנה חזקה — במקום לפצח את WPA2, פשוט **מרמים את המשתמש** למסור את הסיסמה. הנדסה חברתית (מודול 15) פוגשת אלחוט.

🧠 **בדוק את עצמך:** איך מתקפת **Evil Twin** משיגה את הסיסמה גם כשה-WPA2 חזק מדי לפיצוח? (א) היא מפצחת את ה-Handshake מהר יותר (ב) היא מקימה AP מזויף עם אותו שם ומרמה את המשתמש להקליד את הסיסמה בעצמו (Captive Portal - ג) היא משביתה את ה-WPA3

✅ **תשובה: ב** — Evil Twin עוקף את ההצפנה לגמרי: הוא לא מפצח כלום, אלא מטעה את המשתמש למסור את הסיסמה בדף מזויף. זו הנדסה חברתית (מודול 15).

14.8 הגנה על רשת אלחוטית

להמלצות בדוח (מודול 16):

- **סיסמה חזקה וארוכה** (+15 תווים אקראיים) — ההגנה מספר 1 מול פיצוח WPA2.
- **WPA3** במקום WPA2 היכן שאפשר.
- **כבה WPS** — וקטור brute-force מיותר.
- **הפרד רשת אורחים** מהרשת הארגונית (VLAN).
- **WPA2-Enterprise (802.1X / RADIUS)** — אימות פר-משתמש במקום סיסמה משותפת.
- **נטר AP מזויפים** (Rogue AP Detection) מול Evil Twin.

סיכום המודול

- תעבורה אלחוטית משודרת באוויר → הצפנה קריטית; **WEP שבור**, **WPA2** הנפוץ, **WPA3** החזק.
- דורש מתאם עם **Monitor Mode + Injection**; מפעילים עם `airmon-ng`.
- **airodump-ng** סורק; **aireplay-ng** מבצע Deauth ללכידת **Handshake**.
- מפצחים **WPA2 offline** (`aircrack-ng / hashcat -m 22000`) — בדיוק כמו מודול 8.
- **Evil Twin** ו-**WPS** הן מתקפות מתקדמות; Evil Twin עוקף הצפנה דרך הטעיה.
- **הגנה**: סיסמה חזקה, WPA3, כיבוי WPA2-Enterprise, WPS.

מה הלאה?

→ **תרגילים** — `missions.md` · פתרונות — `solutions.md` · תרגול ותרחישים — `practice.md` →

מודול 15 — הנדסה חברתית ופשינג

← חזרה למפת הקורס